

Аудит цепочки поставок: как пентест подрядчика помогает выполнить требования ОАЦ и защитить ваш бизнес

 redsec.by/article/audit-cepochki-postavok-kak-pentest-podryadchika-pomogaet-vypolnit-trebovaniya-oac-i-zashitit-vash-biznes

Red Teams | 27 октября 2025



Почему безопасность ваших подрядчиков — это ваша безопасность

В современной цифровой экономике, построенной на аутсорсинге и сложных взаимосвязях, периметр безопасности вашей организации больше не ограничен стенами вашего офиса или дата-центра. Он простирается до каждого ноутбука разработчика, каждого облачного сервера и каждого сервисного инженера,

предоставляемого вашими подрядчиками. Вы можете инвестировать миллионы в передовые системы защиты, но оставаться уязвимым через самое слабое звено — вашу цепочку поставок.

Статистика неумолима и служит холодным напоминанием о масштабах проблемы. По данным различных исследований, **63% организаций сталкиваются с утечками данных из-за компрометации третьих сторон**, а 61% американских компаний подтвердили, что испытали брешь в безопасности, вызванную подрядчиком. Атакующие прекрасно понимают, что взломать хорошо защищенную корпорацию напрямую — сложно и дорого. Гораздо проще найти в ее окружении небольшого подрядчика с менее зрелой системой безопасности и использовать его доверенный доступ как плацдарм для атаки на основную цель.

Для белорусских организаций, готовящихся к аттестации системы защиты информации Оперативно-аналитического центра (ОАЦ), аудит и управление рисками цепочки поставок перестает быть опцией и становится критической необходимостью. Требования законодательства Республики Беларусь четко указывают на ответственность организации за всю цепочку обработки информации, включая данные, переданные на аутсорсинг.

Громкие инциденты, ставшие хрестоматийными, наглядно демонстрируют разрушительный потенциал атак на цепочку поставок:

- **SolarWinds (2020):** Одна из самых масштабных кибератак в истории. Хакеры скомпрометировали процесс сборки программного обеспечения компании SolarWinds и внедрили вредоносный код в обновления платформы Orion. В результате более 18 000 клиентов, включая правительственные агентства США и крупнейшие корпорации, установили бэкдор прямо в сердце своих сетей.
- **Target (2013):** Классический пример атаки через неочевидного подрядчика. Злоумышленники получили доступ к сети гиганта розничной торговли Target через компрометацию небольшой HVAC-компании (отопление, вентиляция и кондиционирование), у которой был доступ к сети для мониторинга систем. Итог — кража данных 110 миллионов кредитных и дебетовых карт.
- **MOVEit Transfer (2023):** Уязвимость в популярном приложении для безопасной передачи файлов (MFT) затронула около 600 организаций и 35 миллионов человек по всему миру. Атакующие эксплуатировали одну уязвимость в ПО, используемом многими компаниями, что привело к массовой утечке данных.

Эти кейсы объединяет одна закономерность: атакующие не ломились в парадную дверь, а нашли слабое звено в цепи доверия и использовали его для проникновения.

Почему подрядчики — это слабое звено?

1. Асимметрия зрелости информационной безопасности

Крупные организации, особенно в финансовом секторе и госуправлении, вкладывают значительные средства в корпоративные SIEM-системы, строят центры мониторинга (SOC), внедряют решения класса EDR и нанимают штат квалифицированных специалистов. Их подрядчики, особенно представители малого и среднего бизнеса, зачастую не имеют ни ресурсов, ни экспертизы для построения сопоставимого уровня защиты.

Типичные проблемы безопасности у подрядчиков:

- Отсутствие выделенного бюджета на информационную безопасность (ИБ).
- Нехватка квалифицированного персонала; вопросы ИБ часто ложатся на плечи системного администратора.
- Использование устаревшего программного обеспечения и нерегулярное применение обновлений безопасности.
- Слабые политики управления доступом и паролями.
- Полное отсутствие или формальный подход к мониторингу событий и реагированию на инциденты.

Пример из практики: В условиях геополитической нестабильности, компания-подрядчик может стать еще более уязвимой из-за миграции сотрудников, мобилизации и общего стресса. Сотрудник подрядной организации, имеющий доступ к сети заказчика, может во время воздушной тревоги не прервать рабочую сессию из-за эмоционального состояния, чем могут воспользоваться злоумышленники.

2. Доверенный доступ как вектор атаки

Самая большая опасность заключается в том, что подрядчики часто получают привилегированный доступ к критически важным системам заказчика, обходя большинство периметральных средств защиты:

- **IT-аутсорсеры** получают административные права на серверы и контроллеры домена.
- **Разработчики ПО** имеют доступ к исходному коду, тестовым и продуктивным базам данных.
- **Облачные провайдеры** хранят и обрабатывают самые чувствительные данные компании.
- **Бухгалтерские и юридические фирмы** работают с финансовой информацией и коммерческой тайной.

Скомпрометировав учетную запись сотрудника подрядчика, злоумышленник получает "ключи от королевства", и его активность внутри сети выглядит легитимной, что значительно усложняет ее обнаружение.

3. Множественность зависимостей

Современный бизнес зависит от десятков, а иногда и сотен подрядчиков одновременно. Каждый из них представляет собой потенциальный вектор атаки. Контролировать их всех вручную, без систематизированного подхода, практически невозможно, что создает огромную "слепую зону" в управлении рисками.

Требования ОАЦ к управлению рисками третьих сторон

Законодательство Республики Беларусь в сфере кибербезопасности прямо возлагает на организации ответственность за безопасность всей цепочки обработки информации.

- **Указ Президента №40 и Приказ ОАЦ №130:** Эти документы устанавливают требования к обеспечению кибербезопасности, которые распространяются на все организации, независимо от формы собственности. Ключевая идея в том, что обязанность по обеспечению ИБ не заканчивается на границе вашей сети, а охватывает все точки, где обрабатываются ваши данные, включая системы сторонних организаций.
- **Закон "О защите персональных данных" (№99-З):** Этот закон вводит понятие "**уполномоченного лица**" — подрядчика, которому оператор (ваша организация) поручает обработку персональных данных. **Критически важно понимать: оператор несет полную ответственность за действия уполномоченного лица.** Если утечка персональных данных произойдет у вашего подрядчика, штраф (до 200 БВ) получит именно ваша организация.

При прохождении **аттестации системы защиты информации (СЗИ)**, проверяющие от ОАЦ будут тщательно оценивать, как ваша организация управляет рисками, связанными с подрядчиками.

Что проверяется при аттестации:

- **Договорная база:** Наличие в договорах с подрядчиками четких требований по информационной безопасности.
- **Процессы оценки:** Как вы выбираете и проверяете подрядчиков перед началом сотрудничества.
- **Контроль соблюдения:** Как вы убеждаетесь, что подрядчик выполняет заявленные требования.
- **Разграничение доступа:** Предоставление подрядчикам доступа по принципу наименьших привилегий.
- **Мониторинг действий:** Наличие технической возможности отслеживать и анализировать действия сотрудников подрядных организаций в ваших системах.

Если вы не можете продемонстрировать зрелый процесс управления рисками третьих сторон, ваша аттестация может оказаться под угрозой срыва.

Методология аудита безопасности подрядчиков: пошаговое руководство

Эффективный аудит цепочки поставок — это не разовое мероприятие, а непрерывный цикл, состоящий из нескольких этапов.

Этап 1: Инвентаризация и классификация подрядчиков (Risk Tiering)

Невозможно защитить то, о чем вы не знаете. Первый шаг — составить полный реестр всех третьих сторон, имеющих доступ к вашим данным или информационным системам.

После составления списка необходимо классифицировать подрядчиков по уровню риска. Не все они представляют одинаковую угрозу. Для этого используется **модель тирования (Risk Tiering)**.

- **Tier 1 (Критические подрядчики):** Имеют прямой доступ к конфиденциальным данным (персональные данные, коммерческая тайна), их компрометация или отказ в обслуживании приведет к катастрофическим последствиям для вашего бизнеса. *Примеры: основной облачный провайдер, разработчик ERP-системы, IT-аутсорсер с административными правами.*
- **Tier 2 (Важные подрядчики):** Имеют ограниченный доступ к чувствительным данным. Их компрометация нанесет умеренный ущерб. *Примеры: провайдер CRM-системы, подрядчик по технической поддержке сайта.*
- **Tier 3 (Низкорисковые подрядчики):** Не имеют доступа к чувствительным данным. *Примеры: клининговая служба, поставщик канцелярских товаров.*

Матрица классификации рисков подрядчика:

Критерий	Вес	Tier 1 (Высокий риск)	Tier 2 (Средний риск)	Tier 3 (Низкий риск)
Доступ к конфиденциальным данным	40%	Полный, неограниченный доступ	Ограниченный, по запросу	Нет доступа
Критичность для бизнес-процессов	30%	Критичный, остановка бизнеса	Важный, но не критичный	Вспомогательный
Географическое расположение	10%	Регионы с высоким риском	Умеренный риск	Низкий риск
Финансовая устойчивость	10%	Есть риск банкротства	Стабильное положение	Крупный, устойчивый
Замещаемость	10%	Сложно или невозможно заменить	Умеренно сложно	Легко заменить

Основное внимание и ресурсы следует сосредоточить на подрядчиках Tier 1.

Этап 2: Предконтрактная оценка (Due Diligence)

Перед заключением договора с новым подрядчиком, особенно из категории Tier 1, необходимо провести его комплексную проверку. Этот процесс включает отправку детализированных опросников по безопасности и запрос подтверждающей документации.

Checklist для предконтрактной оценки:

- **Общая информация:** Регистрационные данные, опыт, клиенты, структура.
- **Финансовая устойчивость:** Отчетность, наличие страхования киберрисков (Cyber Insurance).
- **Репутационная проверка:** Проверка по санкционным спискам, анализ СМИ, судебные разбирательства.
- **Комплаенс и сертификация:** Наличие сертификатов (ISO 27001, SOC 2), лицензий (включая лицензии ОАЦ).
- **Политики и процессы ИБ:** Наличие политик, программ обучения, планов непрерывности бизнеса (BCP/DRP).
- **Технические меры защиты:** Используемые СЗИ (Firewall, EDR, SIEM), шифрование, MFA, резервное копирование.

- **Управление инцидентами:** Наличие команды реагирования (Incident Response Team), SLA по уведомлению об инцидентах.

Для унификации оценки используются стандартизированные анкеты:

- **SIG (Standardized Information Gathering):** Комплексный опросник (~850 вопросов для Tier 1), охватывающий все аспекты ИБ.
- **CAIQ (Consensus Assessments Initiative Questionnaire):** Бесплатный опросник для оценки безопасности облачных провайдеров.

Этап 3: Оценка результатов и принятие решения

Чтобы систематизировать оценку, используется простая, но эффективная модель, рассчитывающая **Внутренний (Inherent)** и **Остаточный (Residual)** риск.

- **Inherent Risk** — это базовый уровень риска, который несет подрядчик, до учета его мер защиты. $\text{Inherent Risk Score} = \sum (\text{Risk Factor}_i \times \text{Weight}_i)$
- **Residual Risk** — это риск, который остается *после* применения подрядчиком мер защиты. $\text{Residual Risk} = \text{Inherent Risk} \times (1 - \text{Control Effectiveness})$

Пример скоринга:

Подрядчик: CloudProvider XYZ

Tier: 1 (критичный)

Inherent Risk Assessment:

- Доступ к ПДн: HIGH (40 баллов)
- Критичность для бизнеса: HIGH (30 баллов)
- География: Medium (5 баллов)
- Финансовая устойчивость: LOW (2 балла)

Inherent Risk Score: 77/100 (HIGH)

Control Effectiveness (Эффективность контроля):

- ISO 27001 сертифицирован: +15%
- SOC 2 Type II отчет: +20%
- Регулярные пентесты: +10%
- MFA обязателен: +5%

Total Control Effectiveness: 50%

Residual Risk Score: $77 \times (1 - 0.5) = 38.5/100$ (MEDIUM)

Решение: ПРИНЯТЬ с дополнительными условиями (усиленный мониторинг, обязательный еже

Этап 4: Включение требований по ИБ в договор

Все устные договоренности и результаты оценки должны быть юридически закреплены в договоре. Это ваш главный инструмент контроля.

Критически важные пункты для включения в договор:

- **Требования по защите информации:** Конкретные стандарты, обязательство использовать шифрование, MFA и т.д.
- **Право на проведение аудита безопасности:** Это ключевой пункт для белорусских реалий.

"Заказчик имеет право проводить или заказывать у независимых экспертов аудит информационной безопасности Исполнителя, включая тестирование на проникновение (пентест), с уведомлением Исполнителя за 10 рабочих дней. Исполнитель обязуется предоставить необходимый доступ к системам, обрабатывающим данные Заказчика, и документации."

- **Обязательства по уведомлению об инцидентах:** Четко прописанные сроки (например, 24 часа) и процедура уведомления.
- **Обработка персональных данных (для РБ):** Пункты, соответствующие требованиям Закона №99-З (цели, перечень данных, обязательства по защите, порядок уничтожения).
- **SLA по безопасности (Security SLA):** Время восстановления, допустимая потеря данных, штрафы за нарушение.
- **Ответственность и страхование:** Наличие у подрядчика страхования киберрисков и пределы его ответственности.

Пентест подрядчика: можно ли и нужно ли?

Опросники и сертификаты — это хорошо, но они показывают, как *должно быть*, а не как *есть на самом деле*. Пентест — это наиболее объективный способ проверить реальный уровень защищенности подрядчика.

Правовые аспекты в Республике Беларусь:

Проведение пентеста без письменного согласия владельца системы может быть квалифицировано как **несанкционированный доступ к компьютерной информации (ст. 349 УК РБ)**.

Обязательные условия для легального пентеста подрядчика:

- **Пункт в договоре:** Наличие в договоре права на проведение пентеста.
- **Письменное согласие:** Получение официального письма-согласия от руководства подрядчика непосредственно перед началом тестирования.

СОГЛАСИЕ на проведение тестирования на проникновение

Я, [ФИО руководителя], генеральный директор [Название подрядчика], действующий и
Период проведения: с [дата] по [дата].

Настоящим подтверждаю, что являюсь владельцем указанных систем и имею право дава
Дата: _____ Подпись: _____ М.П.

- **Четкое ТЗ (Scope):** Детальное описание целевых систем, разрешенных и запрещенных действий (например, запрет DoS-атак), чтобы избежать ущерба продуктивным системам.

Когда пентест оправдан?

Проведение полноценного пентеста целесообразно для **Tier 1 критических подрядчиков** не реже одного раза в год. Для подрядчиков Tier 2 можно запросить отчет о независимом пентесте, проведенном для них, или ограничиться сканированием внешнего периметра.

Практический кейс: аудит IT-аутсорсера для прохождения аттестации ОАЦ

Ситуация: Белорусская производственная компания (класс 3-юл) готовится к аттестации. Ее IT-инфраструктуру обслуживает подрядчик (Tier 1), имеющий административный доступ ко всем ключевым серверам.

Шаги:

- **Due Diligence:** Опросник выявил "красные флаги": отсутствие сертификатов ISO 27001, отсутствие независимых пентестов, ручной мониторинг логов вместо SIEM.
- **Договор:** В договор с подрядчиком были включены жесткие пункты о праве на ежегодный пентест, требования по обязательному использованию MFA для административного доступа и SLA по уведомлению об инцидентах (24 часа).
- **Проведение пентеста:** Через 6 месяцев заказчик инициировал пентест (Black Box + фишинг).

Результаты:

- **(Критическая)** Уязвимость Log4Shell на портале самообслуживания подрядчика.
- **(Критическая)** Слабые пароли у 2 из 5 администраторов (типа Admin2024!).
- **(Высокая)** Отсутствие MFA на сервере-бастионе (jump-host).
- **(Социальная инженерия)** 3 из 5 администраторов попались на фишинг.
- **Устранение:** Подрядчику был предоставлен отчет с требованием устранить критические уязвимости в течение 30 дней. Он обновил ПО, внедрил MFA, ввел новую политику паролей и провел тренинг для сотрудников.
- **Контроль и повторная проверка:** Повторное сканирование подтвердило устранение уязвимостей.
- **Постоянный мониторинг:** Заказчик подключил подрядчика к платформе Security Ratings (BitSight) для непрерывного контроля и настроил ежеквартальный запрос логов доступа.

- **Результат для аттестации:** При прохождении аттестации компания предоставила комиссии ОАЦ договор, отчет о пентесте и доказательства устранения уязвимостей. Это было расценено как демонстрация зрелого, риск-ориентированного подхода к ИБ и стало весомым аргументом для успешного получения аттестата.

Управление рисками четвертых сторон (Fourth-Party Risk)

Ваши подрядчики используют субподрядчиков (четвертые стороны), например, облачные платформы (AWS, Azure). Риски этих субподрядчиков переносятся на вас.

Стратегии управления:

- **Contractual Flow-Down:** Требуйте в договоре, чтобы ваш подрядчик переносил ваши требования по ИБ на своих субподрядчиков.
- **Visibility:** Требуйте раскрытия информации о критичных субподрядчиках.
- **Right to Approve:** Закрепите за собой право одобрять привлечение субподрядчиков для обработки ваших данных.

Заключение и практические рекомендации

Аудит цепочки поставок — не опциональное удобство, а обязательное требование для организаций, стремящихся к зрелой информационной безопасности и успешному прохождению аттестации ОАЦ.

Практические шаги для начала:

- **(Неделя 1-2) Инвентаризация:** Составьте полный список подрядчиков и классифицируйте их по Tier 1/2/3.
- **(Неделя 3-4) Due Diligence:** Разошлите опросники Tier 1 подрядчикам и запросите сертификаты.
- **(Месяц 2) Ревизия договоров:** Проверьте договоры с Tier 1 подрядчиками и добавьте необходимые пункты по ИБ.
- **(Месяц 3) Пилотный пентест:** Выберите 1-2 самых критичных подрядчиков и договоритесь о проведении ограниченного пентеста.
- **(Месяц 4) Внедрение Continuous Monitoring:** Подключите Tier 1 и Tier 2 подрядчиков к платформе Security Ratings.
- **(Постоянно) Документируйте:** Собирайте все отчеты, сертификаты и процедуры для предоставления комиссии ОАЦ.

Внедрив эти практики, белорусские организации не только повысят шансы успешного прохождения аттестации ОАЦ, но и реально снизят риски утечек данных и компрометации через цепочку поставок. Зрелый подход к управлению рисками третьих сторон — это стратегическое конкурентное преимущество,

демонстрирующее ответственность организации перед клиентами, партнерами и регуляторами.